SKITII TRIALS PLATFORM

# Dedicated Tablet Security

Hospital kiosk model for Yenepoya: power on → only Skitii, MDM dedicated device, app hardening, and lost-tablet revoke.

VERSION
1.1

DATE
August 2026

AUTHOR
Swapnil Sagvekar

CUSTOMER
Yenepoya Hospital

SCOPE
OnePlus Pad Go (OPD2304) + Skitii Trials Yenepoya HNF App (`com.skitiitrialapp`)

## 1. Purpose

Yenepoya will receive Skitii Trial tablets with the clinical app pre-installed. Each tablet is a **dedicated hospital device**, not a personal Android pad.

### Target behaviour

- Power on → only Skitii Trial app runs
- No other apps usable (Play Store, browser, Settings hidden)
- USB debugging and unknown APKs disabled on production units
- Stolen or lost tablet can be wiped remotely and revoked in Skitii admin
- Clinician PIN still required inside the app

This document is the security model and rollout checklist. It is **not** a claim that the device is unhackable. The goal is **ward-grade dedicated-device lock-down**: curious staff or a thief cannot use the tablet as a general Android device, and patient/trial data is protected by OS kiosk + app auth + remote revoke.

---

## 2. Principle: app lock is not device lock

| Layer | What it protects | What it does stop |
|---|---|---|
| Skitii PIN / OTP | Using the clinical app | Home, Play Store, USB, other APKs |
| Device registration (`physicalDeviceRestriction`) | Unregistered tablets calling APIs | OS settings / factory reset |
| Android kiosk + MDM (Device Owner) | Entire tablet UI | Determined attacker with physical access + time |
| Remote wipe + revoke | Stolen unit after report | Data already cached before wipe |

**Rule:** The React Native app alone cannot lock the tablet. Hospital units **must** be enrolled as Android Enterprise **Dedicated Device (COSU)** via MDM.

---

## 3. What Skitii already has vs what hospital tabs still need

| Layer | Today (app repo) | Required on Yenepoya units |
|---|---|---|
| Clinician login | OTP + 4-digit PIN (Keychain) | Keep |
| Device allowlist | `physicalDeviceRestriction` + `physicalDevice` after auth | Keep + **remote revoke on theft** |
| Backup | `android:allowBackup="false"` | Keep |
| Kiosk / lock-task | None | **MDM dedicated device + lock-task** |
| Hide other apps | None | MDM allowlist = Skitii only |
| USB / developer options | Used for lab debug | **Off** on production |
| Root / tamper detect | None | Detect + block app |
| TLS pinning | None | Pin `AUTH_API_URL` / `TRIAL_API_URL` |
| Remote wipe | None | MDM wipe + admin revoke |
| In-app env UI | `UI_CONFIG_SHOW` (must stay `false` in prod) | Confirm off on release APK |
| Build type | Debug used in lab | **Release / signed APK only** |

App package: `com.skitiitrialapp`
App repo: `Skitii-Trials-Yenepoya-HNF-APP`
Reference hardware: **OnePlus Pad Go** (model **OPD2304**, Android 14, OxygenOS)

---

## 4. Recommended model: Dedicated hospital tablet (COSU)

Treat every Yenepoya tab as a **single-purpose clinical device**.

```
Factory reset
    → MDM Device Owner enroll (QR / NFC / zero-touch)
        → Kiosk allowlist: Skitii only
            → Auto-launch Skitii on boot
                → Clinician OTP + PIN
                    → Device ID check against Trial backend
```

**Power on → only Skitii.** No Play Store. No Home / Recents / notifications. No USB debugging. IT can exit kiosk or wipe remotely. Backend can revoke that device ID.

### 4.1 MDM options (India / hospital-friendly)

Any one of these is acceptable if it supports **Android Enterprise Dedicated Device + kiosk**:

- Hexnode
- Scalefusion
- ManageEngine MDM
- Microsoft Intune

Pick **one** vendor, enrol all Yenepoya tabs the same way. Do not mix personal Gmail accounts on these devices.

### 4.2 OnePlus Pad Go (OPD2304) note

OnePlus Pad Go runs **OxygenOS** (ColorOS family). Android Enterprise dedicated-device support can differ from stock Pixel/Samsung. **Validate dedicated-device enrolment on one Pad Go before buying or imaging a batch.** If AE kiosk is blocked by OEM policy, switch MDM profile or hardware SKU before go-live.

---

## 5. Layer 1 — OS lockdown (mandatory)

Do this **before** the tablet leaves Skitii / hospital IT.

### 5.1 Enrolment

1. Factory reset the tablet.
2. Enrol as **Android Enterprise Device Owner** (QR, NFC, or zero-touch) — not a personal Google account.
3. Assign a **Dedicated Device / kiosk** profile.
4. Set lock-task / kiosk package: `com.skitiitrialapp`.
5. Auto-start Skitii on boot.

### 5.2 MDM policy checklist

| Policy | Setting |
|---|---|
| Kiosk / lock-task | Only `com.skitiitrialapp` |
| Status bar / nav bar / Recents | Hidden |
| Notifications | Hidden or severely restricted |
| Play Store | Disabled |
| Unknown sources / sideload | Disabled |
| Multi-user | Disabled |
| Developer options / USB debugging | Disabled |
| Factory reset | Disabled for end user (IT via MDM only) |
| Camera | Allow **in-app only** (patient photo) |
| Screenshots | Disable if Yenepoya IT agrees |
| Wi-Fi | Hospital SSID only (optional MAC allowlist) |
| Bluetooth | Allowed (HR strap / BLE) |
| Location | Allowed (required for BLE scan on Android) |
| Remote lock / wipe | Enabled |
| Personal Google account | Forbidden |

**Do not use app-only `startLockTask()` without Device Owner.** Staff can usually exit it. Device Owner + MDM is the hospital standard.

### 5.3 Clinical peripherals in kiosk

Skitii Trial uses **BLE** (HR strap) and **camera** (patient photo). After kiosk is on, run a clinical smoke test:

- [ ] BLE scan + connect still works
- [ ] Patient photo capture still works
- [ ] Audio / music playback still works
- [ ] App survives screen off / tablet reboot and returns to Skitii only

If a permission is blocked, allowlist **that permission** in MDM — do not open the whole OS.

---

## 6. Layer 2 — App hardening (Skitii product)

OS kiosk stops other apps. These controls protect trial data **inside** Skitii.

### 6.1 Release build only

Hospital tablets must run a **signed release APK**, never a debug build.

```
cd Skitii-Trials-Yenepoya-HNF-APP
source scripts/java17.env
nvm use 24
npm run android:release
```

Install via MDM (preferred) or a controlled IT USB session. **USB debugging must be off after install.**

### 6.2 Two PINs

| PIN | Who | Purpose |
|---|---|---|
| Clinician PIN (existing) | Trial staff | Unlock Skitii after OTP / session |
| IT kiosk-exit / admin PIN | Skitii + Yenepoya IT only | Leave kiosk / open MDM-allowed Settings |

Do **not** document the IT PIN in ward SOPs or on a sticker on the tablet.

### 6.3 Device registration and revoke

Keep the existing gate: authenticated profile with `physicalDeviceRestriction === true` must have `physicalDevice` set, otherwise show **Device not authorized**.

On theft or loss:

1. MDM remote wipe (or lock).
2. Revoke that device in Trial / Product admin so APIs reject it even if PIN is known.
3. Record serial + Skitii device ID + date in the asset log.

### 6.4 Further app work (backlog)

| Item | Why |
|---|---|
| Root / unlock / debugger detection | Refuse to run on tampered OS |
| TLS certificate pinning on GraphQL | Stop MITM on rogue Wi-Fi |
| Idle timeout + re-PIN | Unattended ward tablet |
| Encrypted tokens (Keychain already used for PIN) | Same bar for session tokens |
| `UI_CONFIG_SHOW=false` on prod | No in-app env switcher |
| No cleartext HTTP on prod | Release `usesCleartextTraffic=false` |

These do not replace MDM. They close gaps after kiosk is on.

## 7. Layer 3 — Hospital operations

Cheap controls with high impact.

| Control | Detail |
|---|---|
| Identity | One hospital / MDM tenant — **no personal Gmail** |
| Asset tag | Physical tag + serial + Skitii `deviceId` + Yenepoya site |
| Storage | Nurse station / locked cabinet when not in session |
| Cable lock | Optional for ward desks |
| USB | No charging from unknown laptops; no ADB on production |
| Lost-tab SOP | Report → Skitii + IT → wipe + revoke within minutes |
| Lab vs field | Developer options **only** on Skitii lab units |

## 8. Lab USB / Wi-Fi ADB vs production

Lab pairing (OnePlus wireless debugging / USB udev) is **for Skitii engineering only**.

| Environment | ADB | Developer options | APK |
|---|---|---|---|
| Skitii lab | Allowed (USB preferred) | On | Debug OK |
| Yenepoya production | **Forbidden** | **Off** | Release only |

USB vendor ID for udev on **lab PCs only**: `22d9` (reported as OPPO Electronics Corp. on OnePlus Pad Go). Do not ship lab udev / ADB instructions with the hospital tablet.

## 9. Threat model (honest)

| Threat | Mitigation | Residual risk |
|---|---|---|
| Staff opens Chrome / WhatsApp | MDM kiosk allowlist | Low if Device Owner holds |
| Staff sideloads APK | Unknown sources off + kiosk | Low |
| USB debugging / `adb pull` | Dev options off; no ADB | Low on production image |
| Stolen tablet, still online | MDM wipe + device revoke | Minutes until report |
| Stolen tablet, offline + teardown | Full-disk encryption + no backup + PIN | Determined attacker with time |
| Fake Wi-Fi MITM | TLS pinning (backlog) + hospital SSID | Medium until pinning ships |
| Rooted / unlocked OxygenOS | Root detect (backlog) + AE enrolment | Medium if OEM unlock is possible |
| Shared clinician PIN | Rotate PIN; don't write PIN on device | Process risk |

**"No one can hack this tab" is not a deliverable.** Dedicated device + MDM + revoke + release APK is the correct clinical-trial bar.

## 10. Rollout plan

| Phase | Work | Owner | Exit criteria |
|---|---|---|---|
| 1 | One OnePlus Pad Go (OPD2304): factory reset + MDM dedicated kiosk + release APK | Skitii + Yenepoya IT | Boot → only Skitii |
| 2 | Try to open Settings / Play / USB debug | Yenepoya IT | All blocked |
| 3 | Theft drill: remote wipe + revoke `deviceId` | Skitii | App/API dead; tablet wiped or locked |
| 4 | Clinical smoke: BLE strap, photo, music, reboot | Clinical + Skitii | Session flow works in kiosk |
| 5 | Image remaining tablets the same way (QR enrol) | IT | Identical policy on all units |
| 6 | Asset register + lost-tab SOP signed | Yenepoya | Serial ↔ deviceId list |

Do not batch-enrol until Phase 1–4 pass on the pilot tablet.

## 11. Production go-live checklist

### OS / MDM

- [ ] Factory reset completed
- [ ] Device Owner (not profile owner / personal account)
- [ ] Kiosk package = `com.skitiitrialapp`
- [ ] Auto-launch on boot
- [ ] Play Store, unknown sources, USB debugging off
- [ ] Factory reset blocked for end user
- [ ] Remote wipe tested once
- [ ] Hospital Wi-Fi only (if policy requires)

### App

- [ ] Signed **release** APK
- [ ] `UI_CONFIG_SHOW=false`
- [ ] Points at agreed UAT or production GraphQL URLs
- [ ] Device registered / `physicalDevice` true
- [ ] Clinician can login (OTP + PIN)
- [ ] BLE + camera + music OK in kiosk

### Ops

- [ ] Serial, asset tag, Skitii device ID recorded
- [ ] IT kiosk-exit PIN stored in IT vault only
- [ ] Lost-tablet contact + wipe SOP printed for nurse station
- [ ] No debug cable / ADB leftover on the unit

---

## 12. What not to rely on

- Uninstalling other apps by hand — they return after reset or Play.
- A secret tap inside the RN app to “exit kiosk” as the only lock — it will leak.
- Screen-lock PIN alone — after unlock the user still has full Android.
- Debug APK + USB debugging on a ward tablet.
- App PIN / OTP as a substitute for MDM.

---

## 13. Related repos and IDs

| Item | Value |
|---|---|
| Mobile app | `Skitii-Trials-Yenepoya-HNF-APP` |
| Android applicationId | `com.skitiitrialapp` |
| Trial backend | `Skitii-Trial-Backend` |
| Auth / device APIs | Product GraphQL ( `AUTH_API_URL` ) |
| Trial APIs | Trial GraphQL ( `TRIAL_API_URL` ) |
| Pilot hardware | OnePlus Pad Go (OPD2304, Android 14, OxygenOS) |
| USB vendor (lab udev only) | `22d9` |

## 14. Document control

| Version | Date | Notes |
|---|---|---|
| 1.0 | August 2026 | Initial dedicated-tablet security model for Yenepoya HNF trial |
| 1.1 | August 2026 | Hardware named **OnePlus Pad Go** (OPD2304), not Oppo Pad |